CHUYÊN ĐỀ NGHIÊN CỨU VỀ PHÂN LOẠI MÃ ĐỘC · IT3003.11.CH

Đề tài TAKA10

Phân loại đa nhãn họ mã độc bằng mô hình học sâu kết hợp cơ chế Attention

Học viên
Lê Tuấn Lương

Mã số học viên
250202013

Mã nguồn
github.com/luongIt20/MAL_Class

Bài trình bày trả lời sáu câu hỏi

01 Bài toán cần giải là gì?

02 Dữ liệu lấy từ đâu, chia thế nào?

03 Mô hình hoạt động ra sao?

04 Kết quả tốt đến đâu?

05 Dùng thử như thế nào?

06 Các phiên bản, kết quả cuối, làm gì tiếp?

01 · BÀI TOÁN

Cho một mẫu mã độc Windows, đoán xem nó thuộc họ nào

Đầu vào

Report từ sandbox (mẫu đã chạy trong máy ảo) hoặc một file PE

→

Mô hình

Học sâu kết hợp Attention, đọc nhiều loại bằng chứng cùng lúc

→

Đầu ra

1. Họ A · 0,82
2. Họ B · 0,09

hoặc UNKNOWN nếu không chắc

Họ mã độc: nhóm mẫu chung nguồn gốc và cách hoạt động.

Đa nhãn: một mẫu có thể mang nhiều nhãn họ cùng lúc.

Mục tiêu: đoán đúng ngay lần đầu từ 85% trở lên trên tập test.

01 · Ý TƯỞNG

Nhìn một mẫu từ ba góc rồi cho chúng đối chiếu nhau

Chữ ký

Mẫu khớp dấu hiệu đã biết nào?

Luật YARA, imphash, chữ ký số

Cấu trúc tĩnh

File được xây dựng ra sao?

Header, các section, hàm được import

Hành vi động

Khi chạy, nó làm gì?

Chuỗi lời gọi API, đồ thị process, file, registry

Mỗi góc riêng lẻ đều có thể bị che giấu, ví dụ mã độc bị nén bằng packer. Ghép ba góc lại thì chỗ này thiếu, chỗ kia bù.

02 · DỮ LIỆU

WinMET: report sandbox mã độc thật, có sẵn nhãn họ

31.844

report trong toàn bộ bộ dữ liệu [1]

8.500

report dùng để train, gấp 5 lần bản đầu (1.676)

154 GB

mỗi phần khi giải nén, từ 2,4 GB nén

Nhãn có nhiễu

Nhãn họ do AVClass gộp tên từ nhiều antivirus, nên không phải lúc nào cũng đúng.

An toàn

Chỉ đọc report, giải nén ngay trong bộ nhớ, không bao giờ chạy mẫu.

02 · CHIA DỮ LIỆU

Chia dữ liệu như ra đề: đề thi không trùng bài tập

Tập	Giống như	Dùng để	Số report
Train	Bài tập	Mô hình học	8.500
Validation	Thi thử	Chọn phiên bản tốt nhất	783
Calibration	Chấm mẫu	Đặt ngưỡng tin cậy	216
Test	Thi thật	Chấm đúng một lần, khi đã chốt mô hình	362 + 779

Report nằm chung một khối nén thường rất giống nhau, nên cả khối được xếp vào cùng một tập để tránh **lộ đề**.

03 · MÔ HÌNH

Mô hình làm bốn bước: đọc, tóm tắt, đối chiếu, kết luận

1

Đọc

Tách mẫu thành các mảnh nhỏ (token) theo ba góc

Tokenizer, chuẩn hóa v4

→

2

Tóm tắt

Mỗi góc tự tìm điểm quan trọng của mình

Self-attention, graph attention

→

3

Đối chiếu

Các góc hỏi chéo nhau để ghép bằng chứng

Cross-attention

→

4

Kết luận

Chấm điểm từng họ; không đủ chắc thì UNKNOWN

Family head, ngưỡng

Attention: mô hình tự quyết định nên chú ý vào đâu

Cách hoạt động

Mỗi token hỏi các token khác: *ai liên quan tới mình?* Token càng liên quan càng được chú ý nhiều, token không liên quan gần như bị bỏ qua.

Ví dụ đối chiếu chéo

Hàm import tải file từ mạng **(góc tĩnh)** được nối với sự kiện ghi file rồi chạy file đó **(góc hành vi)**.

Từng dấu hiệu riêng lẻ thì yếu; ghép lại mới thành bằng chứng mạnh.

04 · CÁCH ĐO

Ba con số dùng xuyên suốt phần kết quả

Top-1

Đoán đúng ngay lần đầu.

Mốc so sánh: luôn đoán họ phổ biến nhất đạt **22,1%**.

Top-3

Đáp án đúng nằm trong 3 lựa chọn đầu.

Hữu ích khi người phân tích xem tay vài khả năng.

Macro-F1

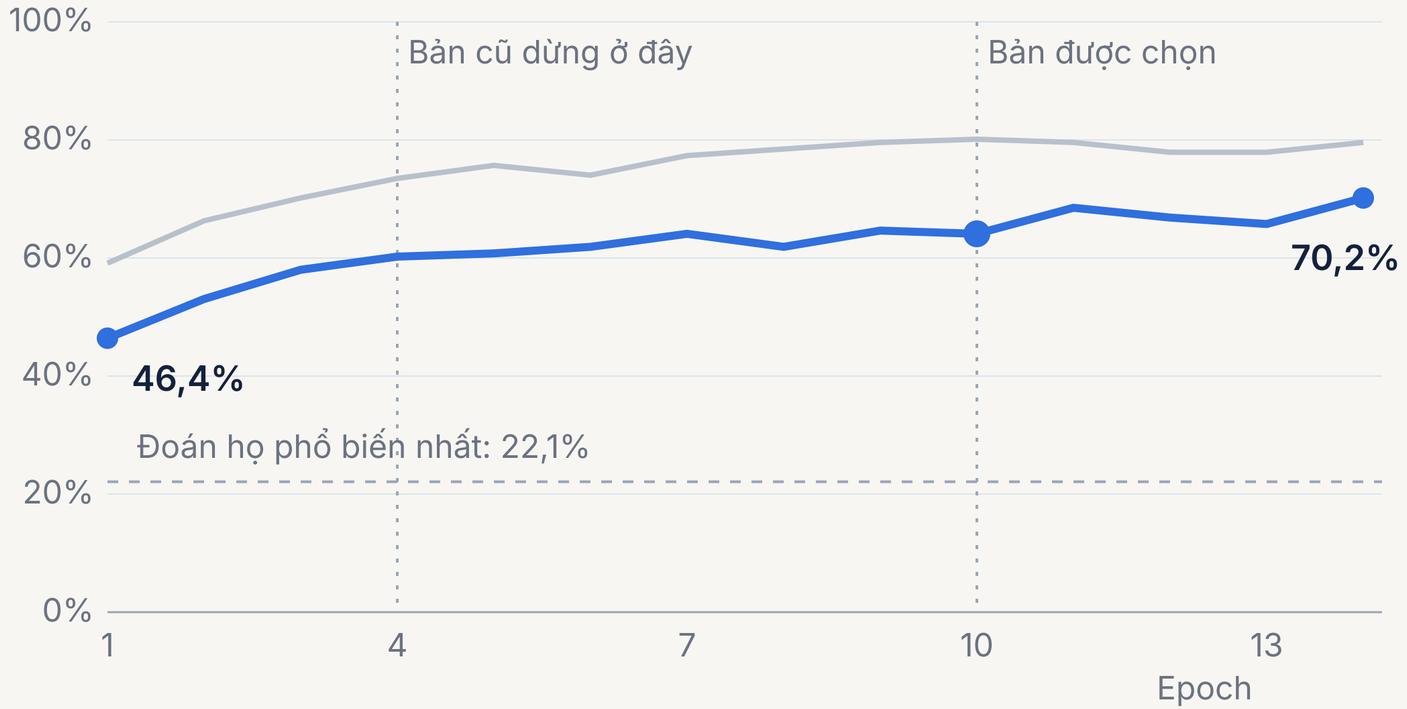
Tính trung bình đều trên mọi họ.

Họ hiếm có trọng lượng ngang họ phổ biến.

Các số tiếp theo đo trên **validation** (181 report có họ đã học). Kết quả test ở slide 17.

04 · KẾT QUẢ

Train đủ lâu: top-1 tăng từ 46% lên 64–70%



64,1%

đoán đúng ngay lần đầu (top-1), bản được chọn

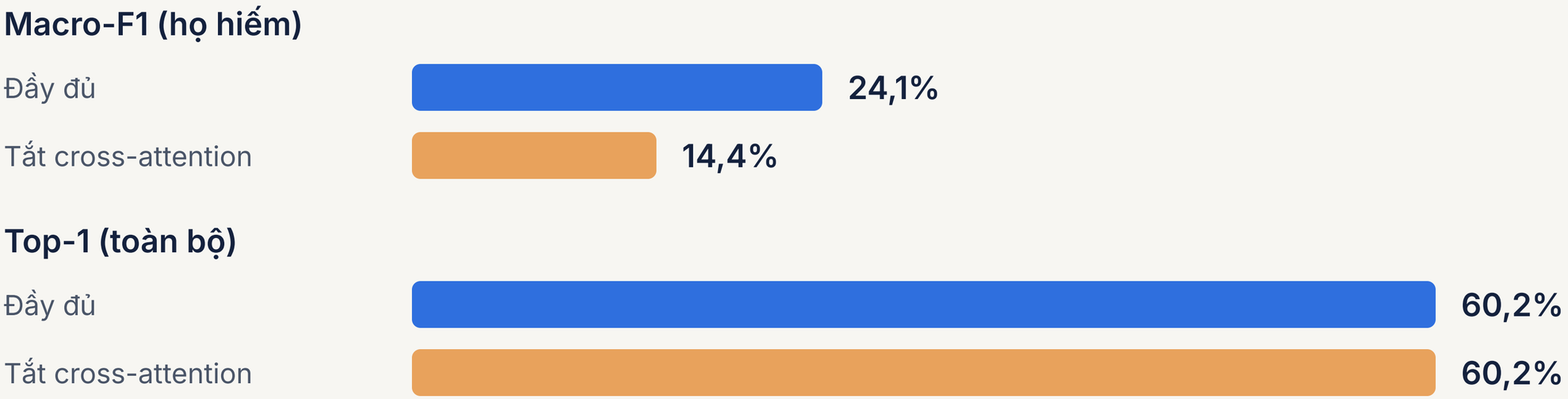
80,1%

đúng trong 3 lựa chọn đầu (top-3, đường xám)

Chọn epoch 10 vì điểm xếp hạng tổng (mAP) cao nhất. Mỗi report ≈ 0,55 điểm phần trăm.

04 · THỬ BỎ BỚT

Tắt đối chiếu chéo, họ hiếm bị đoán sai nhiều hơn hẳn



TAKA10 · Lê Tuấn Lương · 11 · Checkpoint epoch 4 của bản cũ, 181 report validation; thanh cùng thang đo

04 · BIẾT LÚC NÀO KHÔNG CHẮC

Chỉ trả lời khi đủ tự tin thì độ chính xác lên 90,8%

Trả lời mọi report

64,1%

đúng, trên 100% report

Chỉ trả lời khi điểm vượt ngưỡng

90,8%

đúng, trên 54,1% report; còn lại trả UNKNOWN

Ngưỡng đặt trên tập calibration, không dùng validation hay test. Với 47 report thuộc họ chưa học, chỉ 3 report bị trả lời nhầm thay vì UNKNOWN.

05 · ỨNG DỤNG

Dashboard phân tích mẫu mà không bao giờ chạy mẫu

Tự chọn mô hình theo đầu vào

Report có hành vi
→ mô hình ba góc, train trên WinMET

Chỉ có file PE
→ mô hình tĩnh, train trên EMBER2024

Ba lớp an toàn

1. Đọc file PE trong sandbox của macOS: cấm mạng, cấm ghi file, cấm tạo process

2. Quá ít token quen thuộc (dưới 50%) → UNKNOWN

3. Checkpoint khóa bằng SHA-256; sai phiên bản dữ liệu → từ chối

05 · DEMO

Demo: 20 report validation, mỗi report khoảng 0,1 giây

1

Mở dashboard

Chạy trên máy, không cần mạng

2

Nạp 20 report

Xem họ dự đoán, điểm tin cậy, trọng số attention

3

Upload file PE

Xem luồng phân tích tĩnh trong sandbox

8 / 9 report được trả lời là đúng; 11 report còn lại trả UNKNOWN thay vì đoán.

Máy 16 GB: tiết kiệm bộ nhớ để train nhanh gấp đôi

14 → 6,5

phút cho mỗi epoch (một vòng học hết tập train)

2,66 → 0,34

MB bộ nhớ cho mỗi report

Cách làm: chuyển report sang dạng số một lần rồi bỏ dữ liệu thô. Đã kiểm chứng kết quả train giống hệt khi bật và tắt tối ưu.

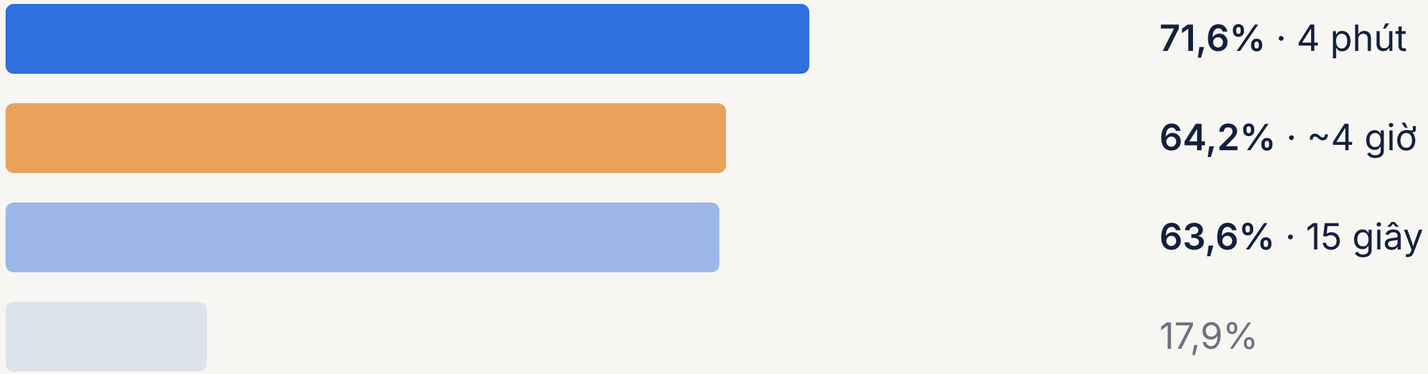
06 · QUÁ TRÌNH NGHIÊN CỨU

Sáu phiên bản, mỗi bản sửa một vấn đề của bản trước

25–26/10	**1 · Mô hình tĩnh EMBER2024**	34.000 mẫu tĩnh · top-1 71,9% (bag 64,6%)
26–27/10	**2 · WinMET 3 nhánh, 1.000 report**	mAP 0,408 so với bag 0,293 (2 seed)
27/10	**3 · Quan hệ giữa các process (v3)**	mAP 0,357 so với bag 0,254
29/10	**4 · Liên kết tài nguyên (v4), 2.500 report**	Dừng ở epoch 4 do tắt máy · top-1 60,2%
11/11	**5 · Train đến hội tụ (run3)**	Top-1 64,1% · chọn lọc 90,8% · **dùng cho demo**
12–13/11	**6 · Dữ liệu ×5 (8.500 report)**	Test: TF-IDF **70–73%** · attention 61–64%

06 · KẾT QUẢ MỚI NHẤT

Trên dữ liệu ×5, một mô hình tuyến tính đơn giản đang thắng



Validation 670 report. **Test chấm một lần**: TF-IDF 73,2% / 70,2%, attention 61,3% / 64,1% (test v1 / v2).

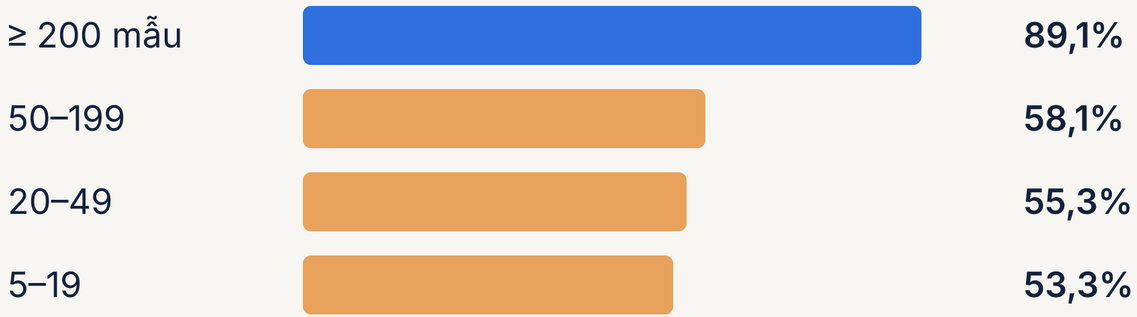
Nhãn từ antivirus gắn nhiều với việc **có hay không** một API cụ thể, nên mô hình tuyến tính học rất nhanh

Attention nhỏ (d_model 32), mới 6 epoch và **vẫn đang tăng**: 50% → 64%

06 · MÔ HÌNH SAI Ở ĐÂU

Họ đủ mẫu đã đúng 89%; lỗi dồn vào họ ít mẫu và nhãn dễ nhầm

Top-1 theo số mẫu train của họ (validation 670 report)



Nhầm nhiều nhất thành **agenttesla**: snakelogger, taskun, noon, msilzilla. Nhiều tên là crypter, nên nhãn có thể **trộn vỏ đóng gói với payload**

MOTIF [15]: so với nhãn chuyên gia, nhãn AVClass chỉ đúng **46,78%**

5 cải tiến không cần train nặng (TF-IDF, kNN, TLSH, cân bằng lớp, signature) đều **không vượt 72–73%** có ý nghĩa

06 · HÀNH VI

Một API riêng lẻ chưa đủ, phải đủ cả chuỗi mới xác nhận

OpenProcess
mở process khác

→

VirtualAllocEx
xin bộ nhớ trong đó

→

WriteProcessMemory
ghi mã vào

→

CreateRemoteThread
chạy mã đó

Thấy 2–3 bước
suspected
1 bước riêng lẻ: bỏ qua

Đủ 4 bước, đúng thứ tự, cùng đích
confirmed: T1055
Process Injection

Ánh xạ
ATT&CK → MBC → NIST
ATT&CK 19.2 · SP 800-53 Rev. 5

Đã có
Luật xác nhận cho 15 kỹ thuật ATT&CK · bằng chứng nhỏ (import, entropy, hash) không bao giờ tự thành “confirmed”

Bước tiếp theo
Train mô hình học hành vi đa nhãn · chứng minh sự kết hợp có ích · đo nhận nhầm trên mẫu lành tính

06 · HẠN CHẾ

Còn cách mục tiêu 85% và chưa thắng baseline mạnh

Tập đo nhỏ

181 report ở bản cũ; bản mới 670 report nhưng mới chạy 1 seed

Nhãn có nhiễu

Nhãn gộp từ nhiều antivirus; có họ mô hình chưa học

Chưa thắng baseline mạnh

Test: TF-IDF 70–73%, attention 61–64%

Có thể lạc quan

58–63% report train mới trùng imphash với test

Máy 16 GB

Mô hình nhỏ, chưa chạy lặp nhiều seed

Giải thích

Trọng số attention chưa chắc là lý do thật của mô hình

06 · ĐỊNH HƯỚNG

Bước tiếp theo: sửa dữ liệu trước, rồi mới tới mô hình

1 · ĐANG LÀM

Nhãn tin cậy hơn

Avast-CTU [16]: 48.976 report CAPE, nhãn do Avast gán, chia theo thời gian · MOTIF [15]: tập kiểm tra chuẩn chuyên gia · đã tải về

2 · MÁY HIỆN TẠI

Hành vi theo chuỗi

Thứ tự event đã có ích (ΔmAP +0,007, khoảng tin cậy không chứa 0) · mô hình lớn hơn d_model 64 · nhãn ATT&CK từ CAPE

3 · CÓ GPU, CÓ NHÓM

Mở rộng, đo chắc

Nhiều seed, mô hình lớn, thêm mẫu lành tính để đo nhận nhầm, thử tấn công né tránh lên chuỗi API

Mục tiêu 85% nên đặt lại trên dữ liệu có nhãn tin cậy. Trên WinMET, cách thực tế là **chỉ trả lời khi đủ chắc**: đúng 90,8% trên 54% số report.

Cảm ơn thầy/cô đã lắng nghe

TÀI LIỆU THAM KHẢO CHÍNH

[1] R. Raducu et al., “A dataset of Windows malware execution traces,” Data in Brief, 2025. · [2] WinMET Dataset, Zenodo, 2025. · [3] M. Sebastián et al., “AVclass,” RAID 2016. · [4] CAPEv2 sandbox. · [5] H. S. Anderson, P. Roth, “EMBER,” 2018. · [6] R. J. Joyce et al., “EMBER2024,” KDD 2025. · [7] A. Vaswani et al., “Attention is all you need,” NeurIPS 2017. · [8] P. Veličković et al., “Graph attention networks,” ICLR 2018. · [9] A. N. Angelopoulos, S. Bates, “Conformal prediction,” 2021. · [12] MITRE ATT&CK 19.2. · [13] NIST SP 800-53 Rev. 5.

Lê Tuấn Lương · 250202013 · github.com/luonglt20/MAL_Class